



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2025-48595 Android Framework Integer Overflow Vulnerability

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-02
Version	1.1
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2025-48595 Android Framework Integer Overflow Vulnerability - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-02 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2025-48595 Android Framework Integer Overflow Vulnerability

1. Executive Summary

CVE-2025-48595 is an Android Framework integer overflow vulnerability that can lead to code execution and local privilege escalation with no additional privileges and no user interaction required, according to Google and NVD. CISA added the issue to the Known Exploited Vulnerabilities (KEV) Catalog on 2026-06-02, indicating exploitation in the wild and elevating its operational priority.

The vulnerability matters most to organizations with managed Android fleets, bring-your-own-device access into enterprise resources, high-risk mobile users, and administrators responsible for patch governance across Android 14, 15, 16, and 16 QPR2-era devices. Public reporting reviewed for this draft does not include exploit code or concrete attacker tradecraft, but Google's bulletin states the issue may be under limited, targeted exploitation.

Defenders should prioritize rapid deployment of the June 2026 Android security update or later, identify exposed devices that lag the required patch level, and treat unmanaged or sideload-capable Android devices as higher risk until patched. Detection and hunting should focus on vulnerable device inventory, unauthorized app installation pathways, and signs that a device has moved from normal application execution into privileged or policy-breaking behavior.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2025-48595
Vulnerability name	Android Framework Integer Overflow Vulnerability
Vendor / project	Android
Affected component	Framework
CWE	CWE-190 (Integer Overflow or Wraparound)
NVD CVSS v3.1	8.4 / High
CVSS vector	CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Access requirements	Local attack vector, no privileges required, no user interaction required
Primary impact	Code execution leading to local privilege escalation
Exploitation status	Known exploited in the wild per CISA KEV; Google states exploitation may be limited and targeted
Security update context	Addressed in the Android Security Bulletin dated 2026-06-01
Affected versions called out by NVD / Android bulletin context	Android 14, 15, 16, and 16-qpr2-era builds referenced in the bulletin and CPE records

3. Source Review & Confidence

This draft is based on three authoritative sources: the CISA KEV catalog entry, the Android Security Bulletin for June 2026, and the NVD record for CVE-2025-48595. Those sources align on the core facts: the issue affects the Android Framework, stems from integer overflow conditions, can enable code execution and local privilege escalation, and is significant enough to warrant urgent patching.

Source	Contribution	Confidence
--------	--------------	------------

Government vulnerability catalog	CISA lists CVE-2025-48595 as an Android Framework integer overflow vulnerability that can allow code execution leading t	High confidence for active-exploitation relevance and response urgency because KEV inclusion is an a
Vendor security bulletin	Google lists CVE-2025-48595 in the Android Framework section of the June 2026 bulletin, categorizes it as an elevation-o	High confidence for affected component, patch context, and exploitation note because this is the pri
NVD vulnerability record	NVD describes the issue as an integer overflow that can lead to code execution and local elevation of privilege with no	High confidence for scoring, vulnerability description, and affected-platform metadata. NVD should b

Confidence is high for the vulnerability's existence, severity, affected platform family, and active-exploitation relevance because those elements are corroborated by both government and vendor sources. Confidence is lower on precise exploitation chains, adversary objectives, and reliable post-exploitation artifacts because none of the reviewed authoritative sources provide exploit samples, forensic indicators, or a root-cause deep dive suitable for defender reproduction.

4. Vulnerability Details

NVD describes CVE-2025-48595 as a vulnerability in multiple locations where an integer overflow can enable code execution and ultimately local escalation of privilege. The Android Security Bulletin places the issue in the Framework component and marks it as an elevation-of-privilege (EoP) issue affecting current Android release families.

Because the attack vector is local and no privileges are required, the practical risk is less about unauthenticated remote exploitation across the internet and more about what can happen after malicious code reaches a device. In enterprise terms, the most relevant concern is that a malicious or compromised application may be able to escape normal sandbox or permission boundaries and obtain elevated execution on a vulnerable device.

The currently available public source set does not provide enough detail to describe the exact vulnerable function, code path, or exploitation prerequisites beyond the vendor and NVD summaries. That limitation should be treated as a collection gap rather than evidence that the issue is hard to exploit; CISA KEV inclusion indicates real-world exploitation was credible enough to justify catalog inclusion.

5. Attack Scenarios

1. Malicious application to privilege escalation chain

- An attacker delivers a malicious Android application to a target device through sideloading, a third-party marketplace, repackaged software, or another initial foothold.
- The application triggers the integer overflow condition in the Framework component and escalates privileges locally.
- Elevated access is then used to disable defenses, access protected data, or establish persistence.

2. Post-compromise privilege expansion on managed mobile fleets

- A device is already compromised through another vector such as credential theft, device misuse, or malicious tooling installed by a user.
- CVE-2025-48595 is used to deepen device access and bypass normal app-level limitations, increasing the impact of the original compromise.

3. Targeted mobile intrusion against high-risk personnel

- Google's bulletin notes possible limited, targeted exploitation.
- This raises the possibility of selective use against journalists, executives, diplomats, or administrators whose Android devices provide access to sensitive communications or enterprise resources.

6. Threat Landscape & Exploitation Status

CISA added CVE-2025-48595 to the KEV catalog on 2026-06-02, which is the strongest public signal in this source set that the vulnerability has been exploited in the wild. Google's bulletin separately notes indications of limited, targeted exploitation. Together, those signals justify treating the vulnerability as an active operational risk rather than a routine patch item.

No reviewed authoritative source attributes exploitation to a named threat actor, ransomware operation, or campaign. Likewise, the available material does not state whether exploitation requires application install rights, physical access, device debugging conditions, or another precursor. Defenders should therefore avoid over-specific assumptions about attacker tradecraft and instead prioritize exposure reduction and disciplined device inventory management.

7. Affected Products and Exposure

The NVD CPE configuration lists vulnerable Android operating-system families including Android 14.0, 15.0, 16.0, and Android 16 QPR2 beta builds. The Android Security Bulletin lists CVE-2025-48595 in the Framework section with updated AOSP versions including 14, 15, 16, and 16-qpr2.

Exposure is highest where organizations:

- allow delayed mobile patching windows
- permit unmanaged Android devices to access corporate resources
- rely on third-party or user-controlled application installation
- support high-risk populations who may face targeted mobile exploitation
- lack MDM, EMM, or mobile-threat-defense visibility into device patch level and app provenance

Organizations that enforce current Android patch levels, restrict sideloading, and gate enterprise access through compliant-device checks materially reduce risk from this issue.

8. Mitigation and Workarounds

Primary mitigation:

- Apply the June 2026 Android security update or a later vendor/OEM patch level that includes remediation for CVE-2025-48595.

Supporting mitigations:

- Verify mobile-device-management policy enforces minimum Android patch levels before permitting access to sensitive services.
- Identify devices that remain on vulnerable Android 14, 15, 16, or 16-qpr2-related builds and prioritize them for remediation or temporary access restriction.
- Restrict or disable sideloading and installation from untrusted sources wherever business requirements allow.
- Review exceptions for rooted, jailbroken, developer-mode, or otherwise non-compliant mobile devices.
- Ensure Google Play Protect remains enabled on devices with Google Mobile Services.
- For environments that cannot patch immediately, reduce exposure by tightening access controls for unpatched devices and monitoring them more aggressively for suspicious app or policy activity.

No reliable public workaround short of patching is identified in the reviewed authoritative sources.

Relevant telemetry

Candidate analytics

False positives and tuning notes

Known blind spots

Signal	Telemetry Source	Analytic Goal
MDM / EMM inventory showing Android version and security patch level	Asset inventory, SBOM, package management, CI/CD telemetry	Find vulnerable builds or packages
Device compliance events for patch lag, developer-mode enablement, rooting	Asset inventory / service / security	Identify vulnerable systems, exposure, or

indicators, or policy bypass	telemetry	suspicious follow-on activity
Mobile threat defense alerts related to suspicious local privilege escalation or defense evasion on Android	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
Enterprise identity and access logs showing sensitive-resource access from non-compliant Android devices	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
Application installation telemetry, especially for sideloaded packages or third-party marketplace installs	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity

9.1 Detection Query

```
// Browser and mobile asset-version pivots for CVE-2025-48595 Android Framework Integer Overflow
Vulnerability
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("edge", "msedge", "android", "adb shell dumpsys package", "winget
list")
| project Timestamp, DeviceName, FileName, ProcessCommandLine
| order by Timestamp desc
```

9.2 Exposure / Triage Query

```
// Service or exposure triage pivots related to CVE-2025-48595 Android Framework Integer Overflow
Vulnerability
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443, 9443)
| summarize ConnectionCount=count() by DeviceName, InitiatingProcessFileName, RemoteIP, RemoteUrl,
bin(Timestamp, 1h)
| where ConnectionCount > 20
| order by ConnectionCount desc
```

Hunt hypothesis

If CVE-2025-48595 exploitation is relevant to the environment, defenders may observe vulnerable Android devices with suspicious application provenance, policy drift, or abnormal access patterns preceding or following elevated-risk device behavior.

Primary pivots

- Devices below the June 2026 patch level
- Devices with sideloading enabled or recent non-Play app installation activity
- High-risk users with Android devices that retain access to privileged enterprise applications
- Mobile threat defense or EMM alerts tied to privilege escalation, rooting, or policy tampering

Priority telemetry sources

- EMM / MDM device inventory and compliance logs
- Mobile threat defense consoles
- Identity-provider and conditional-access logs
- CASB, VPN, or zero-trust access records for mobile-connected sessions
- Endpoint or app-protection telemetry from managed mobile workloads

Triage guidance

If a hit is found, validate whether the device is actually vulnerable, whether the user recently installed unsanctioned software, and whether the device accessed sensitive resources during the exposure window. Escalate quickly if the device belongs to an executive, administrator, journalist, or any other high-risk user population.

Escalation criteria

Escalate to incident response when patch noncompliance is paired with suspicious app installation, mobile threat defense alerts, evidence of rooting or policy bypass, or suspicious enterprise access from the same device.

10.1 Hunt Query

```
// Service or exposure triage pivots related to CVE-2025-48595 Android Framework Integer Overflow Vulnerability
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443, 9443)
| summarize ConnectionCount=count() by DeviceName, InitiatingProcessFileName, RemoteIP, RemoteUrl,
bin(Timestamp, 1h)
| where ConnectionCount > 20
| order by ConnectionCount desc
```

11. MITRE ATT&CK Mapping

Primary ATT&CK mapping:

- T1068 - Exploitation for Privilege Escalation

Analyst note:

- This mapping reflects the privilege-escalation outcome described by Google and NVD. The reviewed sources do not provide enough evidence to map follow-on persistence, credential access, or collection techniques with confidence.

12. Validation / Lab Testing

Lost Boys Cyber did not perform exploit reproduction or device-side lab validation for this draft. The current assessment is based on vendor, government, and NVD reporting only.

Validation priorities for a future lab effort would include:

- confirming patch-level exposure across representative Android device families
- validating how MDM or mobile threat tooling surfaces vulnerable versus remediated devices
- identifying any stable forensic, application, or policy artifacts generated by real or simulated exploitation chains

13. Recommended Actions Summary

4. Patch Android devices to the June 2026 security level or later with immediate priority for executive, administrator, and sensitive-access populations.
5. Enumerate managed and unmanaged Android devices that can reach enterprise services and isolate those that remain below the required patch level.
6. Restrict sideloading and other unsanctioned application-install pathways on corporate or conditionally trusted devices.
7. Review conditional-access, MDM, and mobile-threat-defense controls to ensure vulnerable or non-compliant devices cannot silently retain access to high-value services.
8. Track this issue as an active exploitation risk until fleet-level patch compliance is confirmed.

14. References

9. CISA Known Exploited Vulnerabilities Catalog - CVE-2025-48595
10. Android Security Bulletin - June 2026
11. NVD CVE-2025-48595 record